

Auditing Database Systems

MIS0611403 - System Auditing & Maintenance
Department of Computer Science & Engineering, Uttara University

Conducted by

Farhana Akter Suci

Lecturer, Department of CSE, Uttara University

What You Will Learn

1. Data management approaches
2. Key elements of the database environment
3. Data models
4. Databases in a distributed environment
5. Access controls and audit tests
6. Backup controls and audit tests

Data Approaches: Flat-File Approach

- Flat files are data files whose records have no structured links to other files.
- They belong to legacy systems: large mainframes from the 1970s–80s that some firms still use.
- Until they are replaced by a modern DBMS, auditors must keep working with them.



Separate files with no links between them

Data Approaches: Four Flat-File Problems

1. Data storage

The same data is stored many times, so costs rise.

2. Data updating

A change (e.g. a new address) must be made in every file by hand.

3. Currency of information

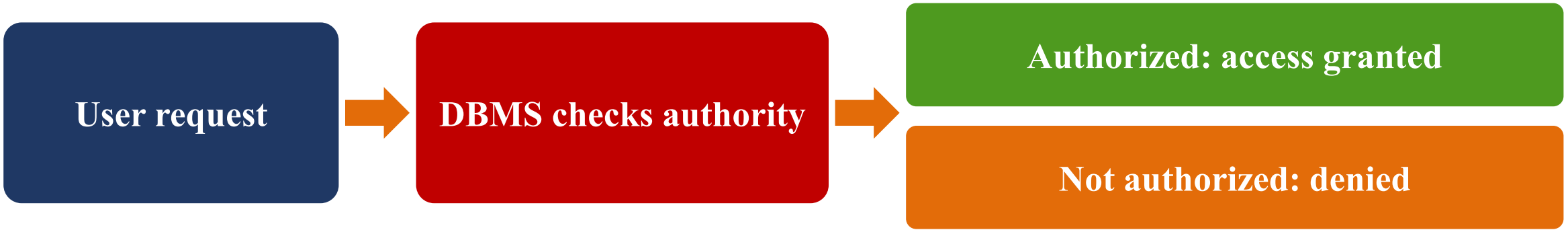
If some copies are not updated, users decide using old data.

4. Task-data dependency

Users can only use their own data; new needs mean new files.

Data Approaches: The Database Approach

- A DBMS is software that controls user access to data.
- It checks each user's authority and grants or denies access, so how authority is assigned matters to auditors.
- All organizational data sits in one shared database that serves every user.

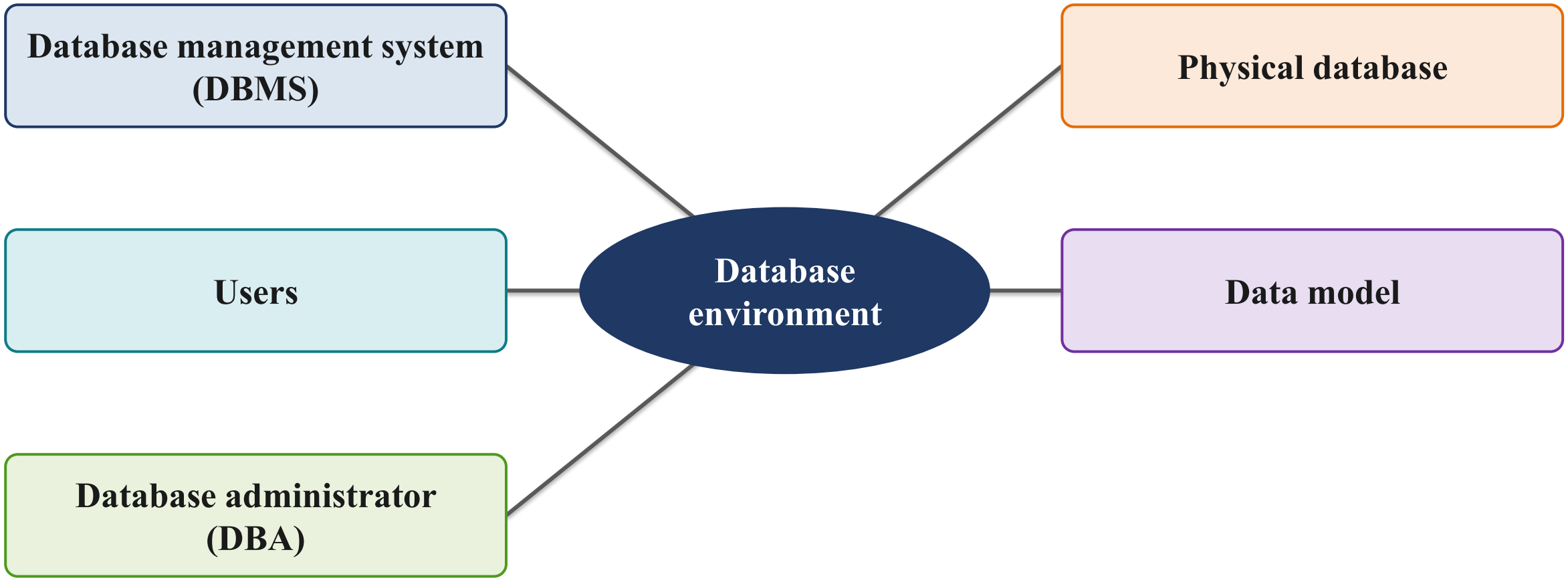


Data Approaches: How a Database Solves Them

Problem	Flat file	Database
Data storage	Same data stored many times	Each data element stored once
Data updating	Update every copy	Update once, in one place
Data currency	Old copies stay in use	Change shows to all users instantly
Task-data dependency	Users limited to their own files	All users share all available data

Example: A billing clerk changes an address; Marketing and Product Services see it immediately.

Database Environment: Five Key Elements



Database Environment: What the DBMS Provides

Program development

Software that lets programmers and end users build applications that access the database.

Backup and recovery

Makes periodic backup copies; after a disk failure, error or attack it restores an earlier correct version.

Database usage reporting

Tracks what data is used, when and by whom; this helps the DBA manage authorization.

Database access

The most critical feature: authorized users reach the data through DDL, DML and the query language.

Database Environment: Three Database Views

View	Also called	What it shows	How many
Internal	Physical view	How records are physically arranged; links between files	One
Conceptual	Logical view (schema)	The whole database, logically and abstractly	One
User	External view (subschema)	Only the part a user may access	Many

Example: A personnel user sees employee records only, not supplier or inventory records.

Database Environment: Handling a Request

1. User program sends a data request (using DML)
2. DBMS checks authorization against the user and conceptual views
3. DBMS finds how the data is stored (internal view) and tells the OS
4. The OS retrieves the data from storage
5. The data is placed in a memory buffer
6. DBMS delivers the data to the user program
7. After processing, data is written back by reversing the steps

Database Environment: The DBA

- The DBA manages the database, protects its integrity and oversees access by many users.

Planning	Design	Implementation and operation	Growth and change
Set strategy, define the environment and requirements, create a data dictionary.	Design logical schemas, user views, internal views and controls.	Define access policies, security, test procedures and programming standards.	Plan for change and evaluate new technologies.

Data Models: Overview

- A data model is an abstract way to show entities, attributes and relationships.
- Hierarchical and network models are navigational: they use explicit links.

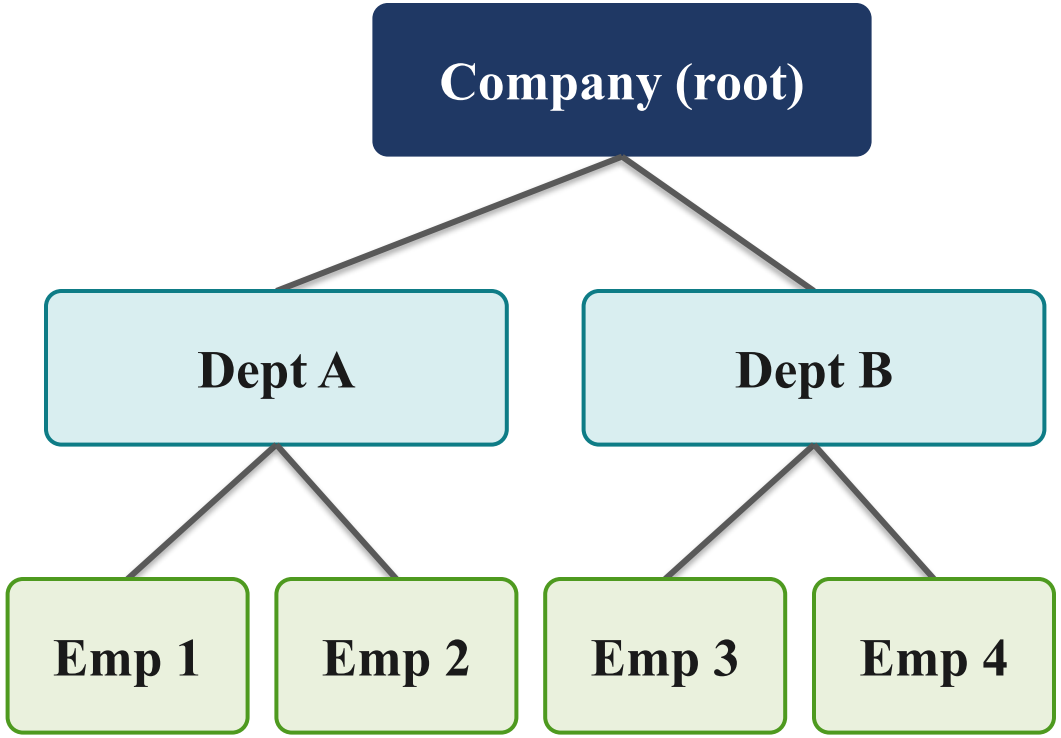
Hierarchical	Network	Relational
Tree-like structure with parent–child relationships	Supports complex many-to-many relationships	Tables with implicit relationships

Data Models: Key Terminology

Term	Meaning
Data attribute (field)	A single piece of data, e.g. name, address, balance
Entity	An object or concept we store data about, e.g. customer, employee, sale
Record type (table / file)	Related attributes that describe one entity
Database	A collection of record types supporting business processes

Data Models: Hierarchical

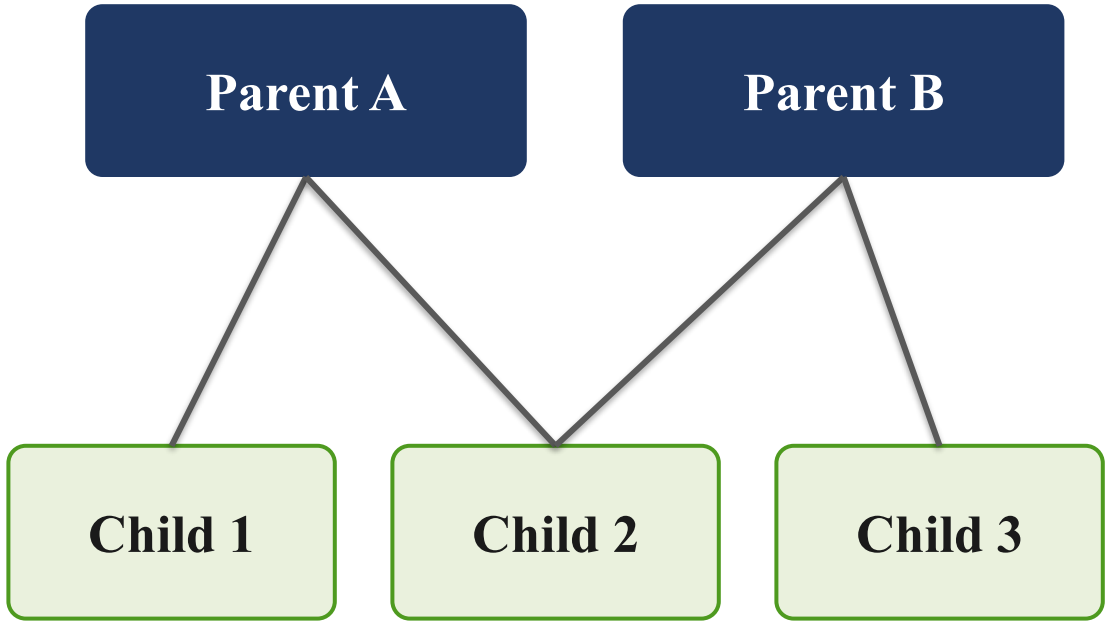
- One of the earliest models: data in a tree with parent–child links.
- A parent can have many children, but a child has only one parent.
- Top level = root; lowest level = leaves; same parent = siblings.
- Example: Company → Departments → Employees.



Emp 1–4 are leaves; Dept A and Dept B are siblings.

Data Models: Network

- Developed by CODASYL in the late 1970s.
- Navigational like the hierarchical model; uses explicit pointers.
- Key feature: a child record can have several parents.



Child 2 has two parents.

Data Models: Relational

- Proposed by E. F. Codd in the late 1960s; based on relational algebra and set theory.
- Data lives in two-dimensional tables (relations).
- Relationships are implicit: no pointers.

CustomerID	Name	City
C101	Rina	Dhaka
C102	Karim	Sylhet
C103	Mita	Khulna

Example table (illustrative)

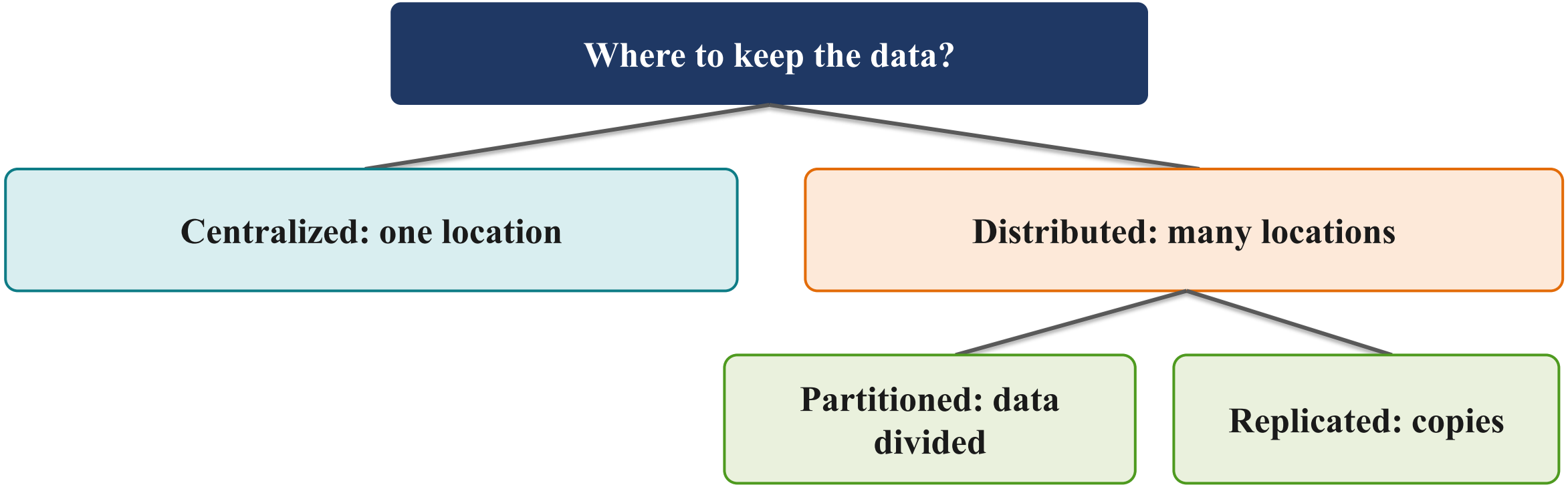
Columns → attributes (fields)

Rows (tuples) → records

Each table → one entity

Distributed Databases: Overview

- The physical structure of data matters when designing a distributed system.



Choose by weighing performance, control and efficiency.

Distributed Databases: Partitioned

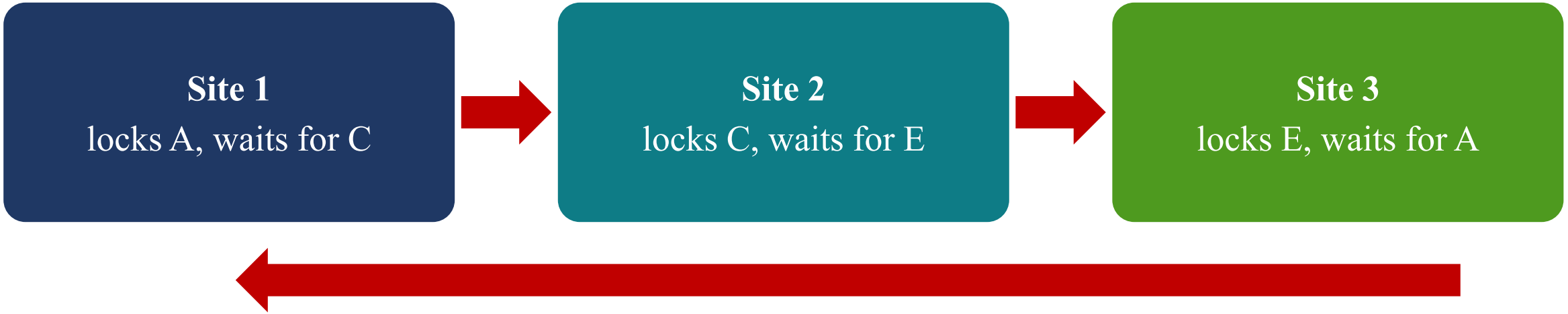
- The central database is split into segments sent to different sites.
- Each site stores the data its own (primary) users need.



Arrows: requests for data between sites

Distributed Databases: Deadlock

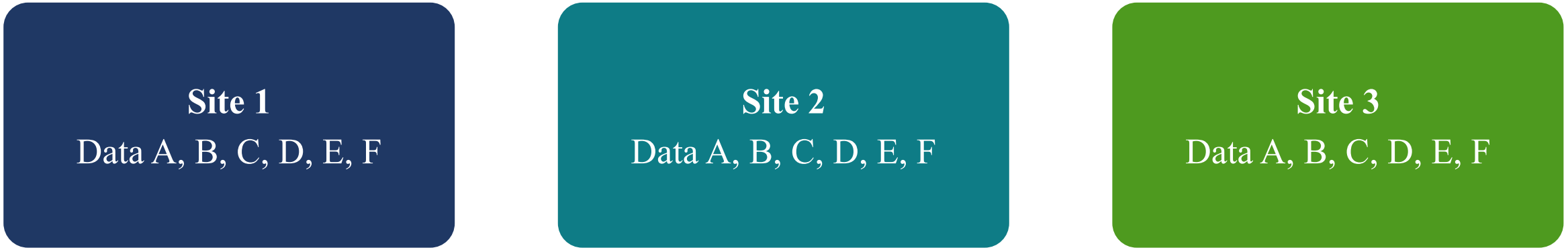
- A deadlock happens when sites lock each other's data and wait forever.
- Result: transactions stop and the system may be corrupted.



Site 3 waits for Site 1, so the circle never ends

Distributed Databases: Replicated

- Copies of the same data are stored at several sites.
- Best when data is shared a lot and no single site is the main user.



Every site holds the full database

Distributed Databases: Concurrency Control

- Concurrency means complete, accurate data at every user site.
- A transaction at one site must show up at all other sites.
- Auditors care because accounting records must be accurate.
- Method: database serialization.



Access Controls: Six Techniques

- They stop unauthorized people from viewing, retrieving, corrupting or destroying data.
- Six techniques:

1. User views	**2. Authorization table**	**3. User-defined procedures**
4. Encryption	**5. Biometric devices**	**6. Inference controls**

Access Controls: Views and Authorization

1. User views (subschema)	2. Authorization table
Define WHAT data a user can see. Limit users to the data they need. They do not control actions such as read, write or delete.	Defines WHAT ACTIONS a user can perform: read, insert, modify, delete. Keeps users within their limits.

Remember: User views decide what you can see; the authorization table decides what you can do.

Access Controls: Audit Objective

Audit objective

Make sure database access rights and privileges match users' legitimate needs.

Who manages authority? → **Do privileges fit roles?** → **Are controls working?**

Access Controls: Audit Procedures

- ✓ Only the DBA manages authority tables and user views
- ✓ Sample users: do privileges match their job roles and levels?
- ✓ Biometrics: weigh cost against benefit (best for very sensitive data, few users)
- ✓ Inference controls: simulate user queries to see if restricted data can be inferred
- ✓ Encryption: examine stored data to confirm passwords and secrets are encrypted

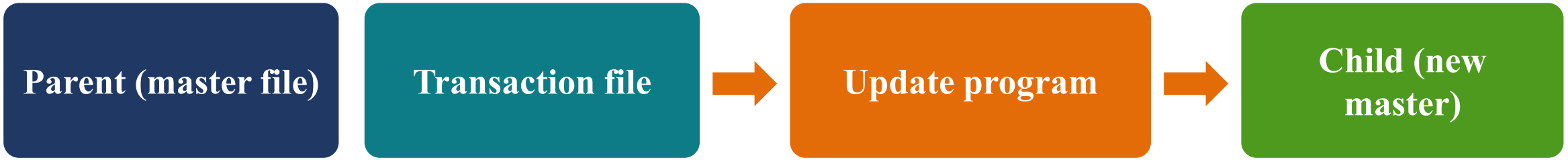
Backup Controls: Purpose

- Protect data from loss, corruption or disaster (hacking, hardware failure, natural disasters).
- Make sure data can be recovered and restored.



Backup Controls: GPC Technique

- GPC = Grandparent–Parent–Child, used for sequential files in batch processing.
- Parent (current master) + transaction file produce the Child (new master).
- Next cycle: Child becomes the new Parent; the old Parent becomes the Grandparent (backup).



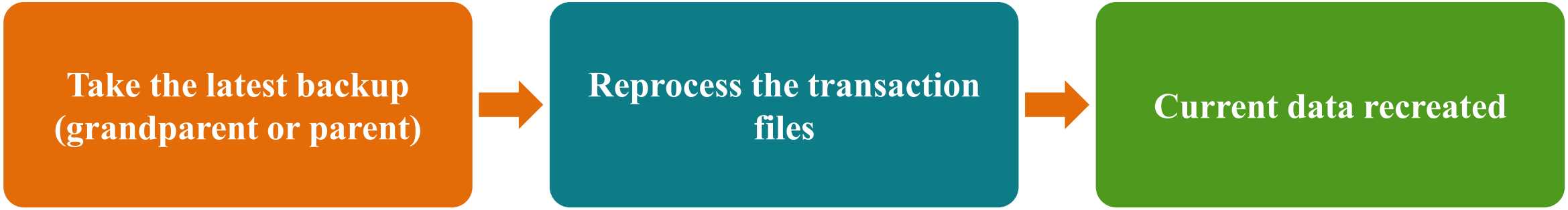
The oldest generation is deleted when the limit is reached.

Backup Controls: GPC Recovery



Newer generations replace older ones as the cycles repeat.

If the current file is lost:



Backup Controls: Database Environment

- Shared data means one bad procedure, malicious act or error can harm every user.

Backup	Transaction log	Checkpoint	Recovery module
Automatic copy of the whole database at least once a day, stored in a secure remote place.	Audit trail of all transactions, plus a database change log of the resulting changes.	Suspends processing, reconciles logs with the database; several times an hour.	Uses logs and backups to restart the system after a failure.

Backup Controls: Audit

Objective: confirm controls keep the database accurate (integrity) and physically secure.

Too rare
heavy reprocessing after a failure

Too often
inconvenient for the business

Balanced backup policy

Auditor checks: backups run routinely (maybe several times an hour), automatic procedures work, and copies are stored off-site.

Quick Review Questions

1. Name the four problems of the flat-file approach and how a database solves them.
2. What are the three database views, and how many of each exist?
3. What is the difference between a partitioned and a replicated database?
4. Why do deadlocks happen, and how are they resolved?
5. List three access control techniques and one audit test for each.

Reference

[1] James A. Hall: Information Technology Auditing & Assurance

Thank You

THANK YOU

Any questions?